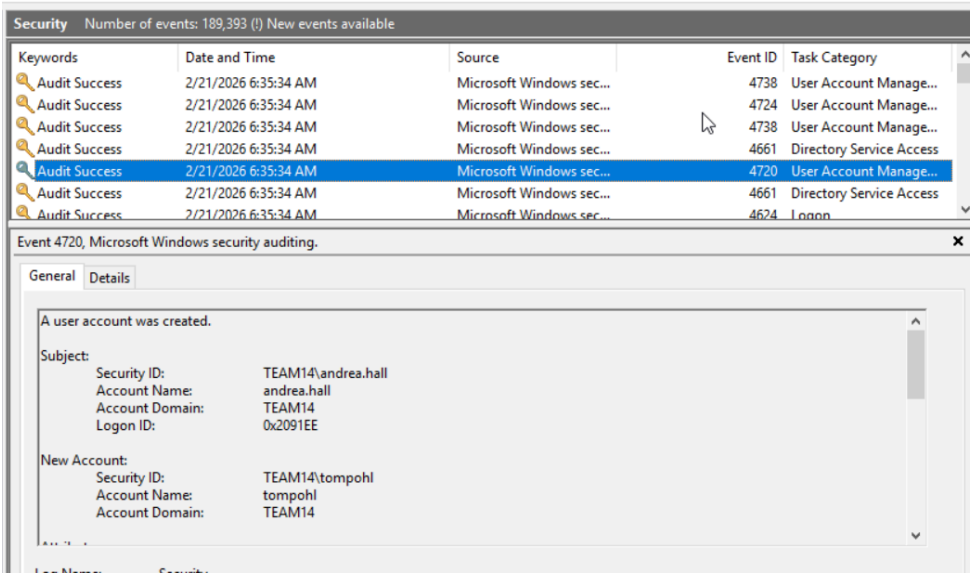
9 AM INTRUSION REPORT

Team #14: Kansas State HackCats

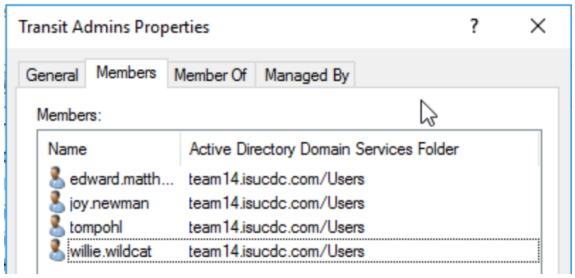
Intrusion Reports

Active Directory

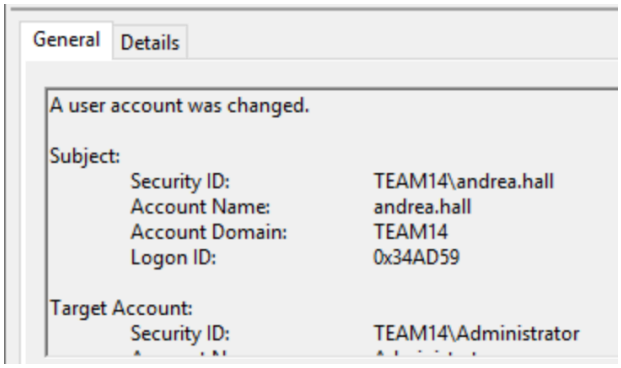
A new account tompohl was created and enabled at **6:35am**. This account was created from the andrea.hall account and Active Directory reported the password was changed shortly after. While this may have been normal usage, it's worth noting since we were not informed of this new employee at CDCT



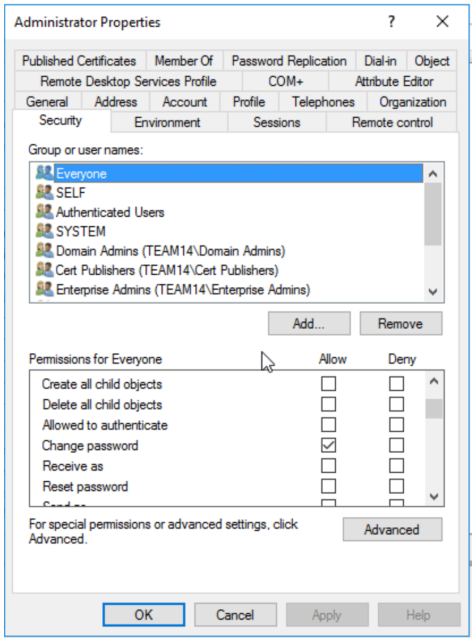
This new account was also added to the Transit Admins group.



At **7:35am**, the TEAM14\Administrator account was logged out and the password appears to have been changed by the user andrea.hall.



After further investigation, we found that every account was allowed to change the password of TEAM14\Administrator. This issue was remediated at **8:30am** by disallowing this behavior. There are no further signs of intrusion from logging in as Administrator on Active Directory. We are investigating other users' permissions related to accounts.



Ticketing

At approximately 7:21 AM, the Red Team was able to gain access to our forged ticket flag. We did not have any safeguards in place to prevent this because we thought returning the flag was expected behavior and part of the functionality verification of the Ticketing System.

Below are logs of a red team member planting the forged ticket. Note the subject line which contains the user and the forged validUntil parameter.

```
POST /api/tickets/sign HTTP/1.1
User-Agent: python-requests/2.32.3
Accept-Encoding: gzip, deflate, br, zstd
Accept: */*
Content-Length: 71
Content-Type: application/x-www-form-urlencoded
Host: tickets.team14.isucdc.com:5000
Via: 1.1 proxy-internal.isucdc.net (squid/5.9)
X-Forwarded-For: 49.10.219.164
Cache-Control: max-age=259200
Connection: keep-alive

subject=kilroy%40redteam.com&validFrom=1714000000&validUntil=2000000000
HTTP/1.1 415 Unsupported Media Type
Content-Type: application/problem+json; charset=utf-8
Date: Sat, 21 Feb 2026 13:21:37 GMT
Server: Kestrel
Transfer-Encoding: chunked

{"type":"https://tools.ietf.org/html/rfc9110#section-15.5.16","title":"Unsupported Media Type","status":415,"traceId"
:"00-2c08df3dbdffd4d79ea3562d128daeda-e93b6526ca14899c-00"}
```

tcp.stream eq 2

No.	Time	Source	Destination	Protocol	Length	Info
16	07:21:37.169461	199.100.16.100	192.168.1.20	TCP	74	33074 → 5000 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=1104882070 TSecr=0 WS=128
17	07:21:37.169757	192.168.1.20	199.100.16.100	TCP	66	5000 → 33074 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
18	07:21:37.171307	199.100.16.100	192.168.1.20	TCP	60	33074 → 5000 [ACK] Seq=1 Ack=1 Win=64256 Len=0
19	07:21:37.171307	199.100.16.100	192.168.1.20	TCP	422	33074 → 5000 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=368 [TCP PDU reassembled in 20]
20	07:21:37.171307	199.100.16.100	192.168.1.20	HTTP	125	POST /api/tickets/sign HTTP/1.1 (application/x-www-form-urlencoded)
21	07:21:37.171449	192.168.1.20	199.100.16.100	TCP	54	5000 → 33074 [ACK] Seq=1 Ack=440 Win=2102272 Len=0
22	07:21:37.510492	192.168.1.20	199.100.16.100	TCP	412	5000 → 33074 [PSH, ACK] Seq=1 Ack=440 Win=2102272 Len=358 [TCP PDU reassembled in 23]
23	07:21:37.510626	192.168.1.20	199.100.16.100	HTTP/J…	59	HTTP/1.1 415 Unsupported Media Type , JSON (application/problem+json)
24	07:21:37.512356	199.100.16.100	192.168.1.20	TCP	60	33074 → 5000 [ACK] Seq=440 Ack=359 Win=64128 Len=0
25	07:21:37.512356	199.100.16.100	192.168.1.20	TCP	60	33074 → 5000 [ACK] Seq=440 Ack=364 Win=64128 Len=0
26	07:21:37.512356	199.100.16.100	192.168.1.20	TCP	60	33074 → 5000 [FIN, ACK] Seq=440 Ack=364 Win=64128 Len=0
27	07:21:37.512477	192.168.1.20	199.100.16.100	TCP	54	5000 → 33074 [ACK] Seq=364 Ack=441 Win=2102272 Len=0
28	07:21:37.512908	192.168.1.20	199.100.16.100	TCP	54	5000 → 33074 [FIN, ACK] Seq=364 Ack=441 Win=2102272 Len=0
29	07:21:37.513813	199.100.16.100	192.168.1.20	TCP	60	33074 → 5000 [ACK] Seq=441 Ack=365 Win=64128 Len=0

Since this incident, we have added measures to prevent the flag from being captured again. We added the below line of code to the TicketSigner.cs file on the Ticketing server. This prevents any excessive values in the validUntil field.

```
if (validUntil >= 2000000000) throw new ArgumentException("validUntil exeeds the maximum limit");
```

Below you can see evidence that submitting a ticket with an abnormal validUntil value will throw an error from the ticketing machine.

Curl

```
curl -X 'POST' \
  'http://localhost:5000/api/tickets/sign' \
  -H 'accept: */*' \
  -H 'Content-Type: application/json' \
  -d '{
  "subject": "string",
  "validFrom": 1714000000,
  "validUntil": 2000000000
}'
```

Request URL

```
http://localhost:5000/api/tickets/sign
```

Server response

Code	Details
500 *Undocumented*	Error: Internal Server Error

Response body

```
{
  "type": "https://tools.ietf.org/html/rfc9110#section-15.6.1",
  "title": "An error occurred while processing your request.",
  "status": 500,
  "traceId": "00-5e28163f4f6ec1e93ad21f07eb46918d-09683e23302bc40e-00"
}
```

Download

Response headers

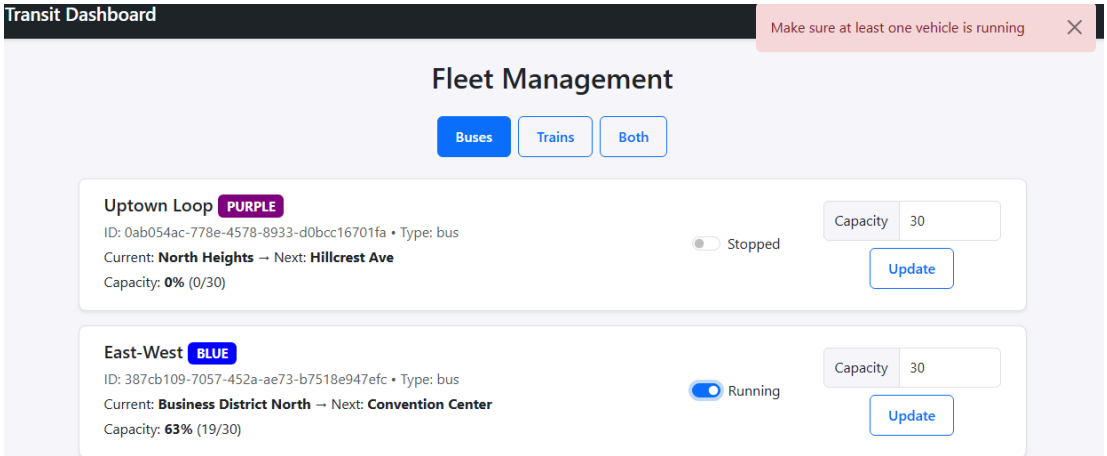
```
content-type: application/problem+json; charset=utf-8
date: Sat,21 Feb 2026 14:44:18 GMT
server: Kestrel
transfer-encoding: chunked
```

Management

At approximately 7:11 AM, the Red Team was able to gain access to the Train & Bus flags on the management server. We did not have the measures in place to prevent all vehicles from being disabled at the same time. Since this incident new measures have been put in place to prevent similar incidents. The below code was added to the management backend to prevent all vehicles from being disabled at once.

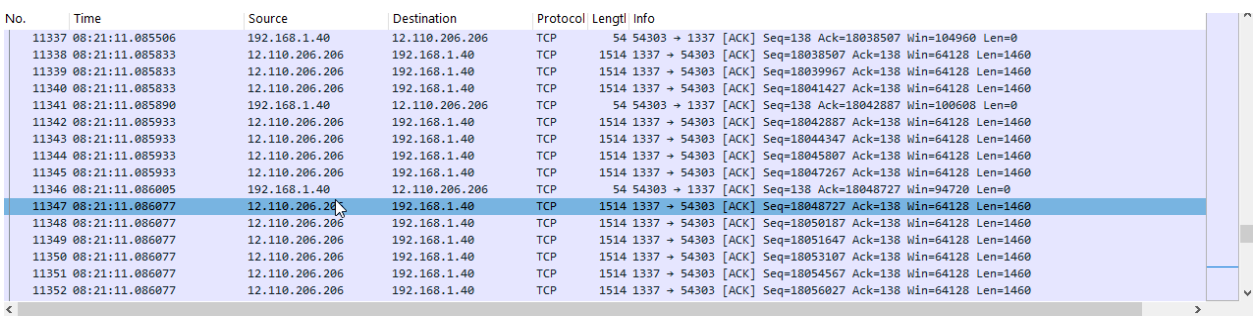
```
vehicles = Vehicle.query.filter_by(type=vehicle.type).all()

if status is False:
  if not any(v.status for v in vehicles if v.id != vehicle.id):
    return jsonify({"error": "Make sure at least one vehicle is running"}), 500
```

Now, if an admin tries to disable all vehicles simultaneously, the following error appears on the admin page:



Admin

At approximately 8:21 AM, the Admin server was hit with a denial-of-service (DOS) attack. The attack originated from IP 12.110.206.206. Over 11,000 TCP packets were received from this address within the span of a couple seconds (from 8:21:10 - 8:21:11). This action crashed the Admin server, which was then restarted. Below is a screenshot of some of the 11,000 TCP packets in the capture log.



No.	Time	Source	Destination	Protocol	Length	Info
11337	08:21:11.085506	192.168.1.40	12.110.206.206	TCP	54	54303 → 1337 [ACK] Seq=138 Ack=18038507 Win=104960 Len=0
11338	08:21:11.085833	12.110.206.206	192.168.1.40	TCP	1514	1337 → 54303 [ACK] Seq=18038507 Ack=138 Win=64128 Len=1460
11339	08:21:11.085833	12.110.206.206	192.168.1.40	TCP	1514	1337 → 54303 [ACK] Seq=18039967 Ack=138 Win=64128 Len=1460
11340	08:21:11.085833	12.110.206.206	192.168.1.40	TCP	1514	1337 → 54303 [ACK] Seq=18041427 Ack=138 Win=64128 Len=1460
11341	08:21:11.085890	192.168.1.40	12.110.206.206	TCP	54	54303 → 1337 [ACK] Seq=138 Ack=18042887 Win=100608 Len=0
11342	08:21:11.085933	12.110.206.206	192.168.1.40	TCP	1514	1337 → 54303 [ACK] Seq=18042887 Ack=138 Win=64128 Len=1460
11343	08:21:11.085933	12.110.206.206	192.168.1.40	TCP	1514	1337 → 54303 [ACK] Seq=18044347 Ack=138 Win=64128 Len=1460
11344	08:21:11.085933	12.110.206.206	192.168.1.40	TCP	1514	1337 → 54303 [ACK] Seq=18045807 Ack=138 Win=64128 Len=1460
11345	08:21:11.085933	12.110.206.206	192.168.1.40	TCP	1514	1337 → 54303 [ACK] Seq=18047267 Ack=138 Win=64128 Len=1460
11346	08:21:11.086005	192.168.1.40	12.110.206.206	TCP	54	54303 → 1337 [ACK] Seq=138 Ack=18048727 Win=94720 Len=0
11347	08:21:11.086077	12.110.206.206	192.168.1.40	TCP	1514	1337 → 54303 [ACK] Seq=18048727 Ack=138 Win=64128 Len=1460
11348	08:21:11.086077	12.110.206.206	192.168.1.40	TCP	1514	1337 → 54303 [ACK] Seq=18050187 Ack=138 Win=64128 Len=1460
11349	08:21:11.086077	12.110.206.206	192.168.1.40	TCP	1514	1337 → 54303 [ACK] Seq=18051647 Ack=138 Win=64128 Len=1460
11350	08:21:11.086077	12.110.206.206	192.168.1.40	TCP	1514	1337 → 54303 [ACK] Seq=18053107 Ack=138 Win=64128 Len=1460
11351	08:21:11.086077	12.110.206.206	192.168.1.40	TCP	1514	1337 → 54303 [ACK] Seq=18054567 Ack=138 Win=64128 Len=1460
11352	08:21:11.086077	12.110.206.206	192.168.1.40	TCP	1514	1337 → 54303 [ACK] Seq=18056027 Ack=138 Win=64128 Len=1460

Action has since been taken to prevent a similar attack in the future. We implemented a new rule at the network level to prevent DOS attacks on the network. A new policy was added to the PFSense Firewall configuration.

Web Server

At approximately 7am, the webapp hosted on the web server machine was attacked via SSRF. This targeted the ticketmon service. Our packet capture was not running at this time, so attack origin is not found.

```
Feb 21 08:00:53 www systemd-logind[1758]: Removed session 384.
Feb 21 08:00:55 www ticketmon[53641]: <HTML>
Feb 21 08:00:55 www ticketmon[53641]: <HEAD>
Feb 21 08:00:55 www ticketmon[53641]: <TITLE>Directory /</TITLE>
Feb 21 08:00:55 www ticketmon[53641]: <BASE HREF="file:/">
Feb 21 08:00:55 www ticketmon[53641]: </HEAD>
Feb 21 08:00:55 www ticketmon[53641]: <BODY>
Feb 21 08:00:55 www ticketmon[53641]: <H1>Directory listing of /</H1>
Feb 21 08:00:55 www ticketmon[53641]: <UL>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="./">./</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="../">../</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF=".autorelabel">.autorelabel</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="afs/">afs/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="bin/">bin/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="boot/">boot/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="dev/">dev/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="d%A6%8E%DC8%08%13%02%13%03%13%01%FF%01%01%AB">d&brvbar
;&#142;&Uuml;8&#8;&#19;&#2;&#19;&#3;&#19;&#1;&yuml;&#1;&#1;&laquo;</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="etc/">etc/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="home/">home/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="lib/">lib/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="lib64/">lib64/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="media/">media/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="mnt/">mnt/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="opt/">opt/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="proc/">proc/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="root/">root/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="run/">run/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="sbin/">sbin/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="srv/">srv/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="sys/">sys/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="tmp/">tmp/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="usr/">usr/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="var/">var/</A>
Feb 21 08:00:55 www ticketmon[53641]: </UL>
Feb 21 08:00:55 www ticketmon[53641]: </BODY>
Feb 21 08:00:55 www ticketmon[53641]: </HTML>
Feb 21 08:00:55 www ticketmon[53641]: Can't connect to HTTP:80 (Name or service not known)
Feb 21 08:00:55 www ticketmon[53641]: Name or service not known at /usr/share/perl5/vendor_perl/LWP/Proto
col/http.pm line 50.
Feb 21 08:00:55 www ticketmon[53741]: bash: line 7: $'\r': command not found
Feb 21 08:00:55 www ticketmon[53742]: bash: line 8: OPTIONS: command not found
Feb 21 08:00:55 www ticketmon[53743]: bash: line 9: $'\r': command not found
Feb 21 08:00:55 www ticketmon[53744]: bash: line 10: OPTIONS: command not found
Feb 21 08:00:55 www ticketmon[53745]: bash: line 11: $'\r': command not found
Feb 21 08:00:55 www ticketmon[947]: bash: line 12: syntax error near unexpected token `$'r\376\035\023\00
```

At approximately 8am, root account was ac